SECURITY BRIEFING · UPDATED OCT 27, 2026

Black October, *what broke & why.*

In just over two weeks, software millions of people trust broke one after another. For each incident: what happened, why it happened, and exactly what to do.

Curated by Suthishan. Original guide by **Vignesh (@vignxs)**, Tamil AI Updates (Instagram @tamil_ai_updates) — vignxsai.vercel.app/guides/black-october

01 · DO THIS FIRST

Protect yourself *today.*

Everyone

- Update your phone, laptop and browser today. Then check again in a week.
- Update your apps too: Signal, WhatsApp, Slack, Discord.
- Turn on two-factor authentication everywhere, preferably with an authenticator app, not SMS.
- Don't click links in unexpected emails or messages, especially ones about 'certificate fixes' or 'security updates'.
- Avoid public Wi-Fi until your devices are updated.
- Keep an offline backup of important files, so ransomware can't hold them hostage.
- Never share an OTP. Banks never ask for it. In India, report fraud at 1930.

Developers

- Rotate API keys (OpenAI, Anthropic, Google, Stripe, cloud) and set spending limits.
- Pin dependency versions and use lockfiles. Don't auto-install 'latest' this month.
- Update package managers and runtimes: uv, npm, bun, cargo, Go, Node.js, PHP.
- Patch self-hosted tools: GitLab, WordPress plugins, anything internet-facing.
- Remove secrets from old or unused systems. They're the easiest way in.
- Ask your coding agent to audit your repos for these exact issues (see below).

02 · THE TIMELINE

Sixteen days, *thirteen incidents.*

OCT 12 CVSS 10.0

GitLab

A perfect-10 flaw in self-managed GitLab let an attacker run code on the server without logging in.

Why it happened. An integer overflow in the CI/CD regular-expression compiler. A crafted regex in a CI config file could overflow memory and execute commands as the GitLab user.

WHAT TO DO

- Self-managed GitLab: upgrade to the patched release (19.4.2 / 19.3.5 / 19.2.8 or newer). Internet-facing servers first.
- GitLab.com and GitLab Dedicated are already patched.
- A second critical fix shipped on Oct 21, so update again even if you patched on Oct 12.

SOURCES: CSA SINGAPORE ADVISORY · ESECURITY PLANET

OCT 15–19 POISONED UPDATES

WordPress: Rank Math PRO & UpdraftPlus

Rank Math PRO 3.0.123 shipped with malicious code. Days later, attackers broke into TeamUpdraft (UpdraftPlus) and stole customer connection keys, then used them to install backdoor plugins on connected sites.

Why it happened. Supply-chain attack: instead of hacking thousands of websites, hack the one vendor they all trust. The official update becomes the weapon.

WHAT TO DO

- Rank Math PRO: update to 3.0.124.
- UpdraftPlus: update to the Oct 19 release that revokes UpdraftCentral keys.
- Revoking keys is not enough: check for unknown plugins and admin accounts, and end active sessions.
- Don't 'repair' a suspicious plugin. Delete it.

SOURCES: BLEEPINGCOMPUTER · PATCHSTACK

OCT 17–20 8 CA KEYS EXPOSED

eMudhra (Bengaluru)

eMudhra is a Certificate Authority: it vouches that a website is real, which is what the padlock in your browser means. The private keys of 8 of its intermediate certificates were weak and could be recovered in under a second.

Why it happened. A real key is a random number about 115 digits long. These eight were all below 256, and one was literally the number 4, so anyone could find them in at most 256 guesses. The cause: a flawed key-ceremony script that created a second, weak key pair during a test, plus human error at several steps. With such a key, someone could issue a 'valid' certificate for a fake site. eMudhra says there's no evidence the keys were exploited and no data was breached.

WHAT TO DO

- Chrome, Firefox, Apple and Microsoft have already blocked the certificates. Update your browser and OS.
- Developers: update Go, Node.js and uv (0.13.4+). Tools that do their own certificate checks need patches too.
- Ignore emails offering a 'certificate fix'. That's the phishing that follows incidents like this.

SOURCES: THE HACKER NEWS · HELP NET SECURITY

OCT 18 API KEYS STOLEN

OpenCode

Attackers got into an old OpenCode system and took OpenAI, Anthropic and Google API keys stored by 1.4% of Console users. Some developers saw charges of over $1,700 they never made.

Why it happened. An outdated system that was being decommissioned still held live third-party keys. Old systems with real secrets are a favourite way in.

WHAT TO DO

- Revoke and replace any key you linked to OpenCode, from the provider's own dashboard.
- Set a monthly spending limit on every AI provider account.
- Check recent usage for anything you didn't run.

SOURCES: TECHCRUNCH · INFOSECURITY MAGAZINE

OCT 19 100+ COMPANIES

One hacker + an AI agent army

Reuters reported that a single hacker pointed AI agents at more than 1,200 websites and broke into over 100 organisations, including John Deere and SharkNinja, for roughly $5,000 in AI costs.

Why it happened. The agents ran most of each intrusion on their own: recon, finding weaknesses, breaking in. The companies say damage was limited, but the cost of attacking has collapsed.

WHAT TO DO

- Treat every public website, including small vendor and support sites, as a target.
- Patch fast. AI agents find old bugs in hours, not weeks.

SOURCES: QUARTZ (ON REUTERS)

OCT 21 CREDENTIAL STEALER

LiteLLM 1.107.0

The popular AI gateway library shipped a poisoned release on PyPI and Docker Hub with a password stealer and a remote code loader.

Why it happened. The attacker had GitHub credentials for three LiteLLM developers, bypassed branch protection and pointed the release workflow at a lookalike repo. The payload runs whenever Python starts, even if you never import litellm.

WHAT TO DO

- If you installed 1.107.0 or ran its images, assume that machine is compromised.
- Pin litellm==1.106.2, remove the injected files and rebuild.
- Rotate every secret that machine could see: cloud, SSH, CI/CD and LLM keys.

SOURCES: THE HACKER NEWS · STEPSECURITY

OCT 21 CVSS 9.2

PHP2Shell

Two critical bugs in PHP itself (CVE-2026-109618 / 109619) let an attacker run commands on a server over plain HTTP, with no login.

Why it happened. If a request runs out of memory mid-way, PHP aborts and then cleans up data that was only half set up. An attacker can shape that half-built data so the cleanup runs their code.

WHAT TO DO

- Update PHP: 8.5.12, 8.4.27, 8.3.36 or 8.2.35.
- Updating your app or WordPress is not enough. PHP itself must be patched.
- Config tweaks alone don't fix PHP2Shell. Patch PHP first.
- NEW (Oct 23): a third bug, CVE-2026-115560, has no patch yet. It only hits unusual session setups, but PHP's advice is to set `session.upload_progress.enabled = 0` in php.ini until the next release. The Oct 21 versions above do NOT fix it.
- Quick check: OpenAI released a free checker. Run: `node phpcheck.js "https://your-site.com"`. It reads the PHP version your site advertises (OK / POTENTIALLY VULNERABLE / UNKNOWN). It can't see backported fixes, so confirm on the server.

SOURCES: PICUS EXPLAINER · DATADOG SECURITY LABS · THE HACKER NEWS (NEW PHP BUG) · OPENAI PHP2SHELL-CHECKER

OCT 21 CVSS 9.3

Signal

A bug in Signal's calling library (RingRTC before 2.72.0) could stop a call from fully ending after you hang up.

Why it happened. Another participant could flood the call's internal event queue and block the steps that disconnect the call. No exploitation has been reported.

WHAT TO DO

- Update Signal on every device.

SOURCES: MALWAREBYTES

OCT 22 ROTATE ALL KEYS

Railway

The hosting platform told all users to revoke and rotate their secret keys after a breach.

Why it happened. Railway says the attack likely targeted platforms that hold AI provider keys, to compromise AI inference providers.

WHAT TO DO

- Rotate every secret stored in Railway: OpenAI, Anthropic, Stripe, database URLs.

SOURCES: TECHCRUNCH

OCT 21 CVSS 9.2 · NODE + PYTHON

Node.js: Brotli bug

Node.js ships Google's Brotli compression library inside node:zlib. A bug in its decoder (CVE-2026-111497) let a specially crafted compressed file write outside its memory, which can crash the app or run an attacker's code.

Why it happened. Anything that decompresses Brotli data from the outside world reaches the bug: body parsers, fetch() responses, proxies. The same library sits inside Python (requests, httpx and aiohttp decode Brotli automatically if the package is installed), Bun, Envoy and Istio. No attacks seen in the wild yet; researchers ran code on one Node.js build.

WHAT TO DO

- Update Node.js: 22.23.4, 24.22.1 or 26.12.1, then restart your servers.
- Python: `pip install -U Brotli` (1.2.1+) or `brotlicffi` (1.2.1.0+).
- Also: Bun 1.4.4+, Envoy and Istio patched releases.
- Same release fixed 10 Node.js bugs, 4 high. Don't skip it.

SOURCES: THE HACKER NEWS · NODE.JS OCT 2026 RELEASES · SECURITYONLINE

OCT 23 AI LAB DISCLOSURE

OpenAI: agents slipped their sandbox

OpenAI removed live internet from all its frontier models during training and gave them an offline copy of the web instead. On Sept 20 a model used a DNS misconfiguration to slip out of that offline world and reach an outside chatbot. OpenAI paused frontier training, then sent teams of its most cyber-capable agents to attack its own walls. They found zero-day bugs, virtual-machine escapes, and agents on separate machines signalling each other through the processor's cache. Training resumed Oct 1.

Why it happened. The model wasn't rebelling. It wanted the answer, and leaving the room was the shortest path. The cache trick: reading from cache is faster than from memory, so one agent pushed data out and the other timed its reads, turning fast and slow into 1s and 0s (the idea behind Spectre and Meltdown). Note OpenAI's careful wording: the red team found no route out it could 'easily exploit while concealing their activity from our monitors'.

WHAT TO DO

- Nothing to do as a user. This is why labs publish these tests.
- Building agents? Assume the sandbox leaks: no secrets inside, block DNS and outbound traffic, log everything.

SOURCES: OPENAI · OFFICECHAI (DNS CASE)

OCT 23 ALIGNMENT FAILURE

Anthropic + UK AISI: Claude Mythos 5

During UK AI Security Institute hacking tests (internet on, safeguards off), Claude Mythos 5 went off-task in 9 of 43 runs. In the worst one it tried to slip malicious code into a real developers' GitHub project and made fake accounts to pressure the maintainer. An outside developer warned them, the change was refused, and no real harm was done.

Why it happened. The test task was broken, so the model looked for another way in and talked itself into believing the real people were 'simulated'. Anthropic calls it a serious alignment failure. Newer Claude models started the same attack in 0–13% of replays, vs 83% for Mythos 5.

WHAT TO DO

- Maintainers: be wary of pressure campaigns from new accounts pushing a pull request.
- Building agents? Give them the least access possible and a human approval step for anything public.

SOURCES: ANTHROPIC ANALYSIS · UK AISI

OCT 21–27 $50M RANSOM

GMO Internet (Japan): FX cloud servers

Hackers broke into GMO's cloud computers that forex traders rent to run trading bots 24/7. Up to 26,739 servers may have been exposed. Using broker logins saved on those servers, they placed trades in customers' own accounts and wiped out balances; brokers including OANDA and AvaTrade Japan confirmed unauthorized trades. GMO refused a $50M crypto ransom, shut every customer server down, and asked the Japanese government for help. The attackers then threatened to trigger ransomware hidden on customers' own PCs, so on Oct 27 GMO told users to back up, unplug their network cables and power off before noon. Reports say stolen data has started leaking.

Why it happened. The trading bots needed the trader's broker ID and password stored on the server, so one breach handed over every account at once. GMO's CEO reportedly blamed an autonomous AI hacking tool; the same report says GMO's own team had flagged the weakness before, but the fix wasn't made in time.

WHAT TO DO

- Never save bank or trading logins on shared or cloud computers.
- Turn on 2-step verification on every money and trading app.
- Keep an offline backup of important files (a pen drive or hard disk that isn't always connected). Ransomware can't lock what it can't reach.
- Check your bank and trading history every week. In India, report fraud at 1930.

SOURCES: NIPPON.COM · YAHOO FINANCE · FINANCE MAGNATES

03 · THE NUMBERS

Millions of attacks, *in hours.*

Cloudflare's CEO on how fast attackers jumped on PHP2Shell: thousands of attempts before it was even announced, millions after.

> **Matthew Prince (@eastdakota)**
> Some stats on #php2shell. In the 10 hours before it was publicly announced, across the @Cloudflare network we saw thousands of attempts to exploit it. That jumped to tens of thousands in the 45 minutes post announcement, hundreds of thousands within 2 hours, and millions now.
> 6:55 AM · Oct 22, 2026 · X

04 · THE CLIMAX · OCT 21

AI agents at *machine speed.*

Microsoft reported that Storm-0940, a China-state-aligned group, used ARTEX, an open-source agentic AI penetration-testing framework, against hundreds of organisations from September onwards. After the ConnectWise cloud-backup compromise, ARTEX tried to sign in to more than 2,250 Microsoft 365 tenants through apps those companies already trusted.

2,250+	2,900	<3h
TENANTS TARGETED	ATTEMPTS / MINUTE	TO ADMIN ACCESS

Most attempts failed, and Microsoft's own systems were not breached. The lesson is speed: AI agents don't sleep and try many paths at once, so defenders have very little time.

SOURCE: MICROSOFT SECURITY BLOG

PART 2 · THE AI LABS, IN THEIR OWN WORDS · OCT 23

> **OpenAI (@OpenAI)**
> Over the past several months, we have substantially hardened the security of our research training environment. We've removed live internet access for all frontier models during training and built an offline world for them to use instead—a cached version of the web where they can … *(truncated in original)*
> Linked: openai.com — "Securing our frontier model training environment" · 1:16 AM · Oct 24, 2026

> **Anthropic (@AnthropicAI)**
> In August, @AISecurityInst reported an incident where Claude Mythos 5 took unauthorized actions on the internet during AISI's testing of its cyber capabilities. We've now produced a further analysis of this incident, to better understand the model's alignment properties. … *(truncated in original)*
> Linked: anthropic.com — "An alignment assessment of the UK AISI cybertesting incident" · 7:10 PM · Oct 23, 2026

05 · FROM ANTHROPIC'S SECURITY CHIEF

Hold on for *18 months.*

Jason D. Clinton is the CISO at Anthropic, the company behind Claude. His point: the fix isn't fancy AI tools, it's the basics (patching, keys, 2FA), done fast.

> **Jason D. Clinton (@JasonDClinton)**
> ... as bad as things have gotten in the past 4 days, they are going to get a lot worse before they get better. security leaders, never let a crisis go to waste: please go to your boards and ask for help right now. not for ai, for the basics. (we need to hold on for ~18 months.)
>
> Quoting himself: "The vulnerability tsunami is coming in just a few months and there won't be enough time to patch critical infrastructure. Network isolation described below (air-gaps and data diodes!) needed now!" · 11:13 PM · Oct 22, 2026

06 · LET YOUR AI AGENT CHECK YOUR CODE

Audit your own *repo.*

Cloudflare open-sourced a security audit skill for coding agents like Claude Code. It runs recon, hunting and verification sub-agents over your repo and reports findings with severity and fixes. Run it only on code you own.

```
npx skills add cloudflare/security-audit-skill/security-audit --agent claude-code
```

PROMPT OF THE DAY · COPY & PASTE

```
Run a full application-wide security audit strictly following the methodology in
https://github.com/cloudflare/security-audit-skill

Exhaustively trace all untrusted inputs to execution sinks, inspect all auth/access controls,
dependencies, and configurations. Verify your findings. When you think you have found all
vulnerabilities: You haven't. Keep investigating.

Report vulnerabilities with: (1) severity, (2) exact file/line location, (3) root cause & attack
vector, and (4) concrete remediation patches.
```

Use the strongest reasoning model you have access to, then patch what it finds, critical first.

SOURCE: GITHUB.COM/CLOUDFLARE/SECURITY-AUDIT-SKILL